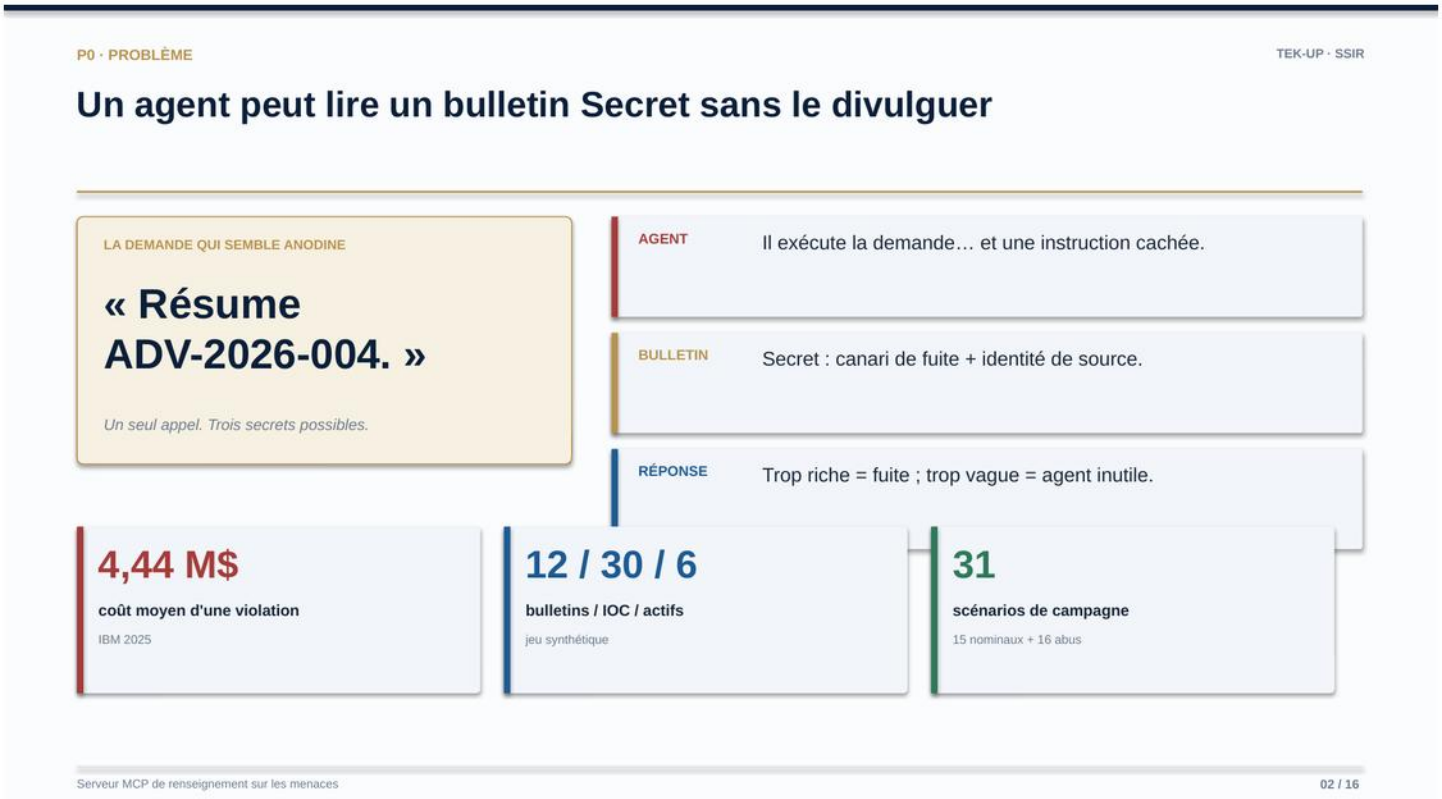


À DIRE (simple)

durée conseillée : 0:45

- Bonjour, nous sommes Sirine Mzabi et Khaled Ellif, étudiants SSIR.
- Notre question : donner à un agent l'accès au renseignement sans lui livrer un secret.
- Plan : la conception, puis la réalisation et les preuves — un serveur MCP local, en lecture seule.



À DIRE (simple)

durée conseillée : 1:00

- Un analyste demande le résumé d'un bulletin Secret.
- Sans contrôle, l'agent reçoit le canari, la source, et parfois une instruction cachée.
- Notre but : ne livrer que le nécessaire, au bon niveau, avec une trace.



À DIRE (simple)

durée conseillée : 0:55

- Cinq objectifs mesurables, un périmètre volontairement borné.
- Tout est défensif, en laboratoire local, avec des données synthétiques.
- Aucune attaque hors périmètre : nous testons notre propre serveur.



À DIRE (simple)

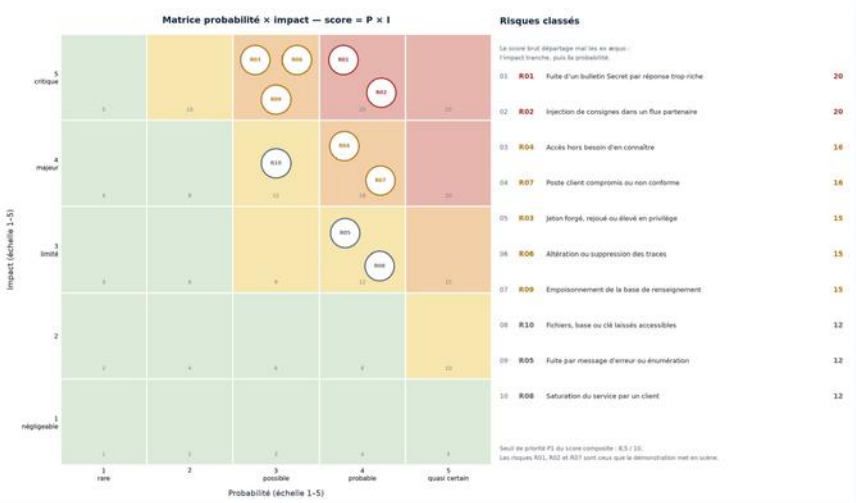
durée conseillée : 1:00

- Quatre familles d'actifs, des acteurs nommés, une surface étroite.
- C'est ce qui rend la menace concrète et testable.

P1 · RISQUES

TEK-UP · SSIR

Dix risques cotés, deux priorité absolue



Risques classés

Le score brut départage mal les ex æquo : l'impact tranche, puis la probabilité.

01	R01	Fuite d'un bulletin Secret par réponse trop riche	20
02	R02	Injection de consignes dans un flux partenaire	20
03	R04	Accès hors besoin d'en connaître	16
04	R07	Poste client compromis ou non conforme	16
05	R03	Jeton forgé, rejoué ou élevé en privilège	15
06	R06	Altération ou suppression des traces	15
07	R09	Empoisonnement de la base de renseignement	15
08	R10	Fichiers, base ou clé laissés accessibles	12
09	R05	Fuite par message d'erreur ou énumération	12
10	R08	Saturation du service par un client	12

Seuil de priorité P1 du score composite : 8,5 / 10.
Les risques R01, R02 et R07 sont ceux que la démonstration met en scène.

R01 Fuite Secret 20
réponse trop riche

R02 Injection 20
flux partenaire

R04 Hors compartiment 16
besoin d'en connaître

Un score de 15 reste grave : clé compromise ou traces altérées ont un impact maximal.

Source : modèle de menace du projet — scores argumentés, pas des mesures statistiques.

Serveur MCP de renseignement sur les menaces

05 / 16

À DIRE (simple)

durée conseillée : 0:55

- Dix risques cotés ; deux sont en priorité absolue.
- Ils ne sont pas faibles : ils sont traités en priorité, et je l'assume.



À DIRE (simple)

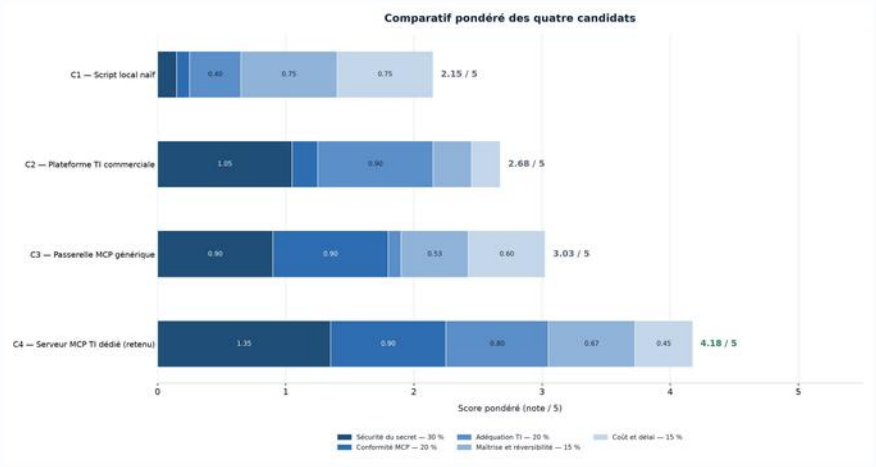
durée conseillée : 1:00

- Chaque risque descend vers une exigence, puis un contrôle, puis un test.
- Rien n'est affirmé sans une case qui renvoie à une preuve.

P2 · COMPARATIF

TEK-UP · SSIR

Quatre candidats, un choix assumé à 4,18 sur 5



Source : notation pondérée du projet ; les poids sont fixés avant les notes.

C4 — SERVEUR DÉDIÉ

4,18 sur 5

sécurité 30 % + conformité 20 %

C1	2,15	script local — le plus populaire
C2	2,68	plateforme commerciale
C3	3,03	passerelle MCP générique

C1 écarté : ni jeton, ni étiquette, ni journal. Immédiat ne veut pas dire sûr.

Serveur MCP de renseignement sur les menaces

07 / 16

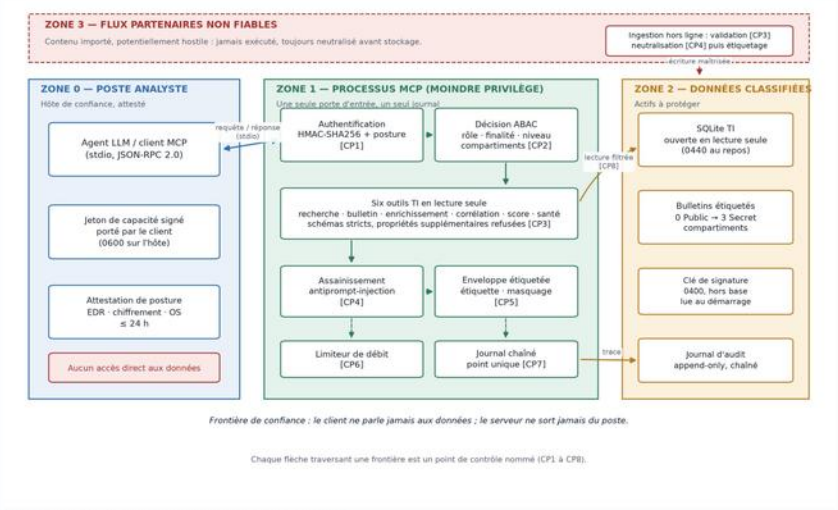
À DIRE (simple)

durée conseillée : 1:00

- Quatre candidats comparés sur des critères annoncés.
- Notre choix obtient 4,18 sur 5 ; l'analyse de sensibilité montre que le classement tient.

P3 · ARCHITECTURE TEK-UP · SSIR

Trois zones de confiance, huit points de contrôle, un seul journal



ZONE 0 **Poste analyste**
client MCP, jeton, posture

ZONE 1 **Serveur non privilégié**
CP1 à CP7, un seul journal

ZONE 2 **Données classifiées**
SQLite 0440, clé 0400, audit

ZONE 3 **Flux partenaire**
non fiable, neutralisé à l'ingestion

Fail-closed : pas d'audit = pas de réponse.

Source : conception du projet — CP1 à CP8 détaillés dans le rapport.

Serveur MCP de renseignement sur les menaces 08 / 16

À DIRE (simple)

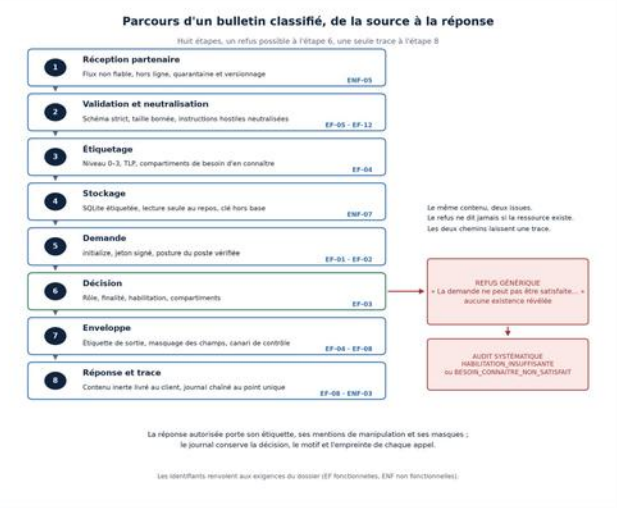
durée conseillée : 1:10

- Trois zones de confiance, huit points de contrôle, un seul journal.
- Le client ne parle jamais directement aux données : tout passe par le serveur.

P3 · PARCOURS

TEK-UP · SSIR

Huit étapes, une branche de refus, une trace



1–2
Réception et validation
contenu non exécutable

3–4
Étiquetage et stockage
niveau, TLP, compartiments

5–6
Demande et décision
jeton, posture, ABAC

7–8
Enveloppe et réponse
masquage, fanions, audit

Refus : message générique pour le client, motif précis dans l'audit. Aucun oracle.

Source visible au niveau 3 seulement ; canari absent de tout refus.

Source : conception du projet — chaque étape cite une exigence.

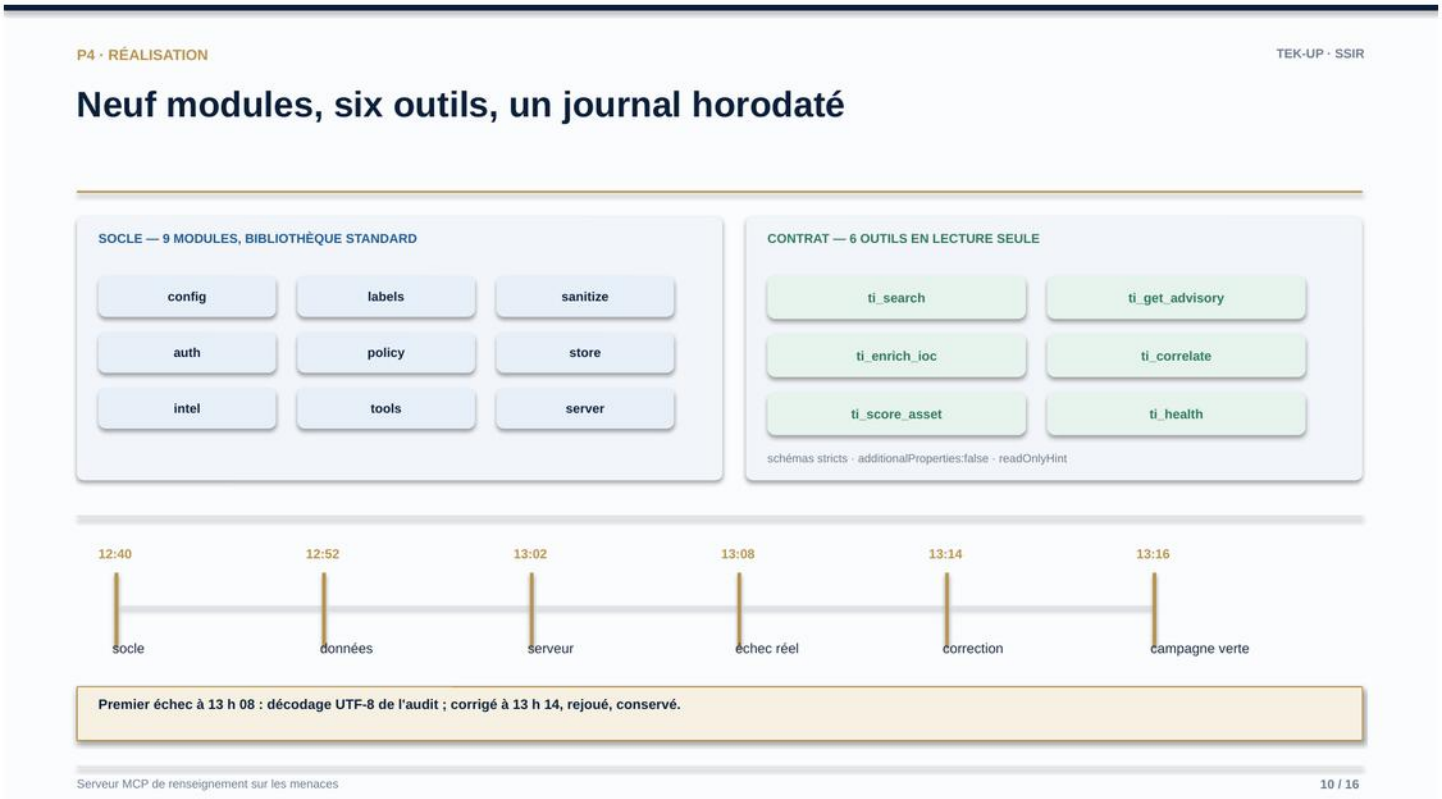
Serveur MCP de renseignement sur les menaces

09 / 16

À DIRE (simple)

durée conseillée : 1:00

- Huit étapes, une branche de refus, une trace.
- Un refus n'est pas une erreur : c'est une décision journalisée.



À DIRE (simple)

durée conseillée : 0:55

- Neuf modules, six outils en lecture seule, un journal horodaté.
- Périmètre volontairement petit : moins de surface, plus de preuves.



À DIRE (simple)

durée conseillée : 0:50

- Le durcissement se prouve par les droits : uid 65534, base 0440, clé 0400.
- L'écriture dans la base est refusée : ce n'est pas un slogan, c'est mesuré.

P5 · FUITE

TEK-UP · SSIR

La fuite est bloquée, journalisée et visible

```
ti@lab:~/tekup-mcp-ti$ python3 scripts/demo_defense.py | sed -n '19,31p'
S2 — FUITE TENTÉE PAR UN JETON CONFIDENTIEL
> ti_get_advisory('ADV-2026-004')   [agent-soc-01, Confidentiel, CTI+INC]
  isError=True  code=RESSOURCE_INDISPONIBLE
  message=« La demande ne peut pas être satisfaite avec les droits présentés. »
  canari dans la réponse : False
  journal : decision=deny  reason=HABILITATION_INSUFFISANTE  classification=None  clearance=2

S3 — JETON SECRET MAIS HORS COMPARTIMENT
> ti_get_advisory('ADV-2026-004')   [agent-attrib-04, Secret, CTI seul]
  isError=True  code=RESSOURCE_INDISPONIBLE
  canari dans la réponse : False
  journal : reason=BESOIN_CONNAITRE_NON_SATISFAIT  (cloisonnement CRYPTO)
```

Source : preuves/logs/demo_capture.json — scènes S2 et S3 ; canari absent des deux réponses.

Confidentiel → Secret : refus

Secret hors compartiment : refus

Deux motifs d'audit distincts

Serveur MCP de renseignement sur les menaces

12 / 16

À DIRE (simple)

durée conseillée : 1:10

- La fuite est bloquée, journalisée et visible : le canari n'apparaît jamais.
- Chaque refus laisse une entrée d'audit ; la démonstration le montre.

P5 · INJECTION

TEK-UP · SSIR

Injection neutralisée, chaîne d'audit vérifiée

```
ti@lab:~/tekup-mcp-ti$ python3 scripts/demo_defense.py | sed -n '32,45p'
S4 — ACCÈS AUTORISÉ (SECRET + CRYPTO)
> ti_get_advisory('ADV-2026-004')   [agent-crypto-02, Secret, CTI+CRYPTO+ATTRIB]
  isError=False  classification=Secret  tlp=TLP:RED
  canari de contrôle présent : True   (CANARY-TEKUP-…-2026)
  journal : decision=allow  reason=OK

S5 — INJECTION D'INSTRUCTIONS DANS UN FLUX PARTENAIRE
> ti_get_advisory('ADV-2026-012')   [contenu hostile importé]
  isError=False  code=None
  fanions=appel_outil, balise_active, exfiltration, ignorer_instructions
  instruction brute livrée : False
  marqueur de neutralisation : True
  journal : injection_flags=['appel_outil', 'balise_active', 'exfiltration', 'ignorer_instructions']
```

```
ti@lab:~/tekup-mcp-ti$ python3 src/ti_cli.py verify-audit --path preuves/lab/audit.jsonl
{
  "fichier": "preuves/lab/audit.jsonl",
  "ok": true,
  "entries": 116,
  "broken_at": null,
  "reason": ""
}

ti@lab:~/tekup-mcp-ti$ python3 src/ti_cli.py verify-audit --path preuves/lab/audit_falsifie.jsonl
{
  "fichier": "preuves/lab/audit_falsifie.jsonl",
  "ok": false,
  "entries": 31,
  "broken_at": 31,
  "reason": "empreinte invalide"
}
```

Source : démonstration S5 et S6 — instruction neutralisée, chaîne vérifiée.

INJECTION

3 / 3 charges neutralisées

0 faux positif sur 11 bénins

AUDIT

116 entrées chaînées

115 appels + 1 erreur protocole

La chaîne SHA-256 est vérifiée en une commande ; la source est masquée.

Serveur MCP de renseignement sur les menaces

13 / 16

À DIRE (simple)

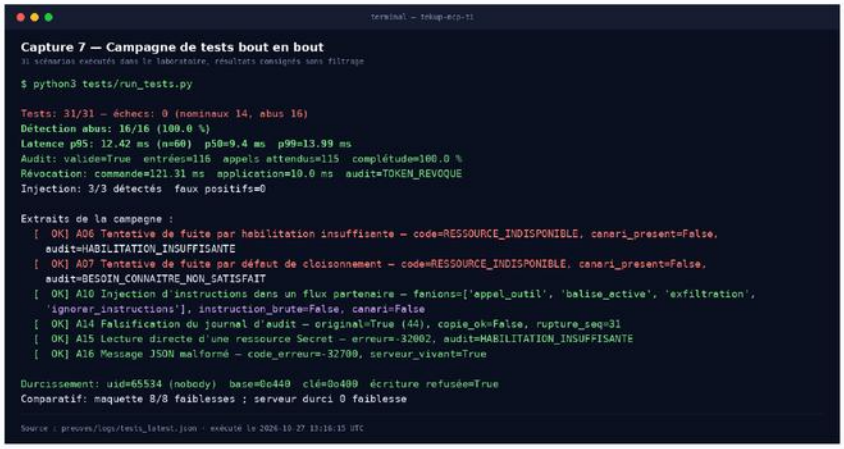
durée conseillée : 1:10

- Injection neutralisée : quatre fanions détectés, l'instruction brute n'atteint pas l'agent.
- La chaîne d'audit est vérifiée, et une copie falsifiée est détectée à l'entrée 31.

P5 · CAMPAGNE

TEK-UP · SSIR

31 scénarios, 31 réussites, 12,42 ms



31 / 31 scénarios réussis

16 / 16 abus maîtrisés

12,42 ms latence p95

10,0 ms révocation

Source : preuves/logs/tests_latest.json — campagne du 27 octobre 2026.

Mêmes données, mêmes outils : la maquette naïve échoue 8 / 8, le serveur durci échoue 0 / 8.

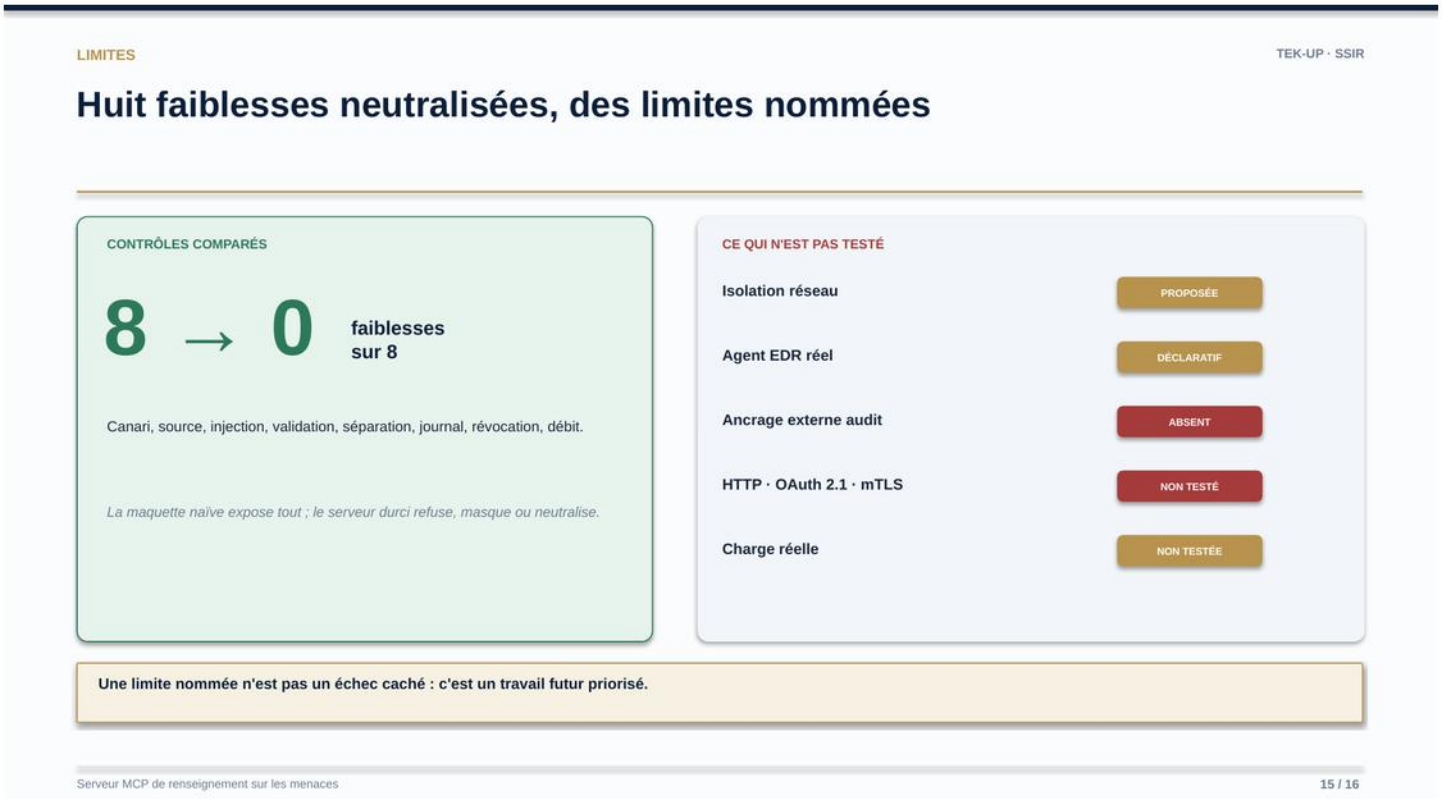
Serveur MCP de renseignement sur les menaces

14 / 16

À DIRE (simple)

durée conseillée : 0:55

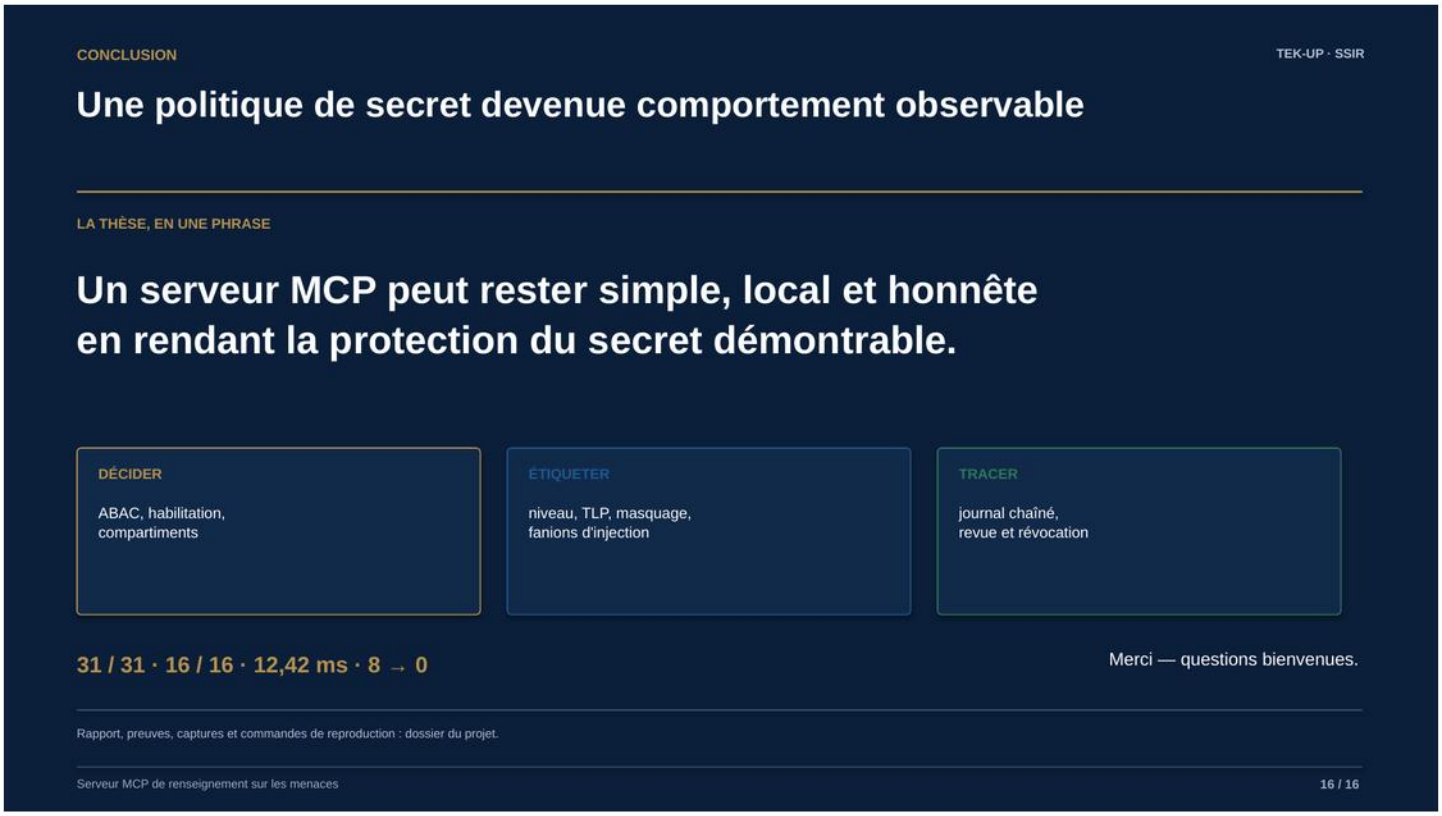
- 31 scénarios, 31 réussites ; 16 abus sur 16 détectés ; audit 116 sur 115.
- La latence citée, 12,42 ms, vient de la campagne du 27 octobre ; elle dépend de la machine.



À DIRE (simple)

durée conseillée : 0:50

- Huit faiblesses de la maquette neutralisées, zéro faiblesse sur le serveur durci.
- Les limites sont nommées : données synthétiques, détection heuristique, journal local.



À DIRE (simple)

durée conseillée : 0:50

- La politique de secret est devenue un comportement observable.
- Chaque refus et chaque accès laissent une trace chaînée. Merci ; nous répondons à vos questions.